

SAML Vulnerabilities

Security Assertion Markup Language) is widely used for authentication. It uses XML schema and is prone to multiple security vulnerabilities. Some of the common security issues are

Index	Technique
1	Signature Wrapping (XSW) Attacks
2	XML Attacks
3	SAML Message Integrity Abuse
4	Missing / Invalid Signature
5	SAML Message Replay
6	CSRF
7	XML Comment Handling
8	XSLT
9	Token Recipient Confusion
10	Labs & Resources
11	Report

Signature Wrapping (XSW) Attacks

XSW Attacks happen when the XML Digital Signature (XML DSig) is not validated which is used to

This attack can lead to situations like Privilege Escalation, Authentication Abuse & Denial of

Resource:

<https://research.aurainfosec.io/bypassing-saml20-SSO/>

Burp Extention:

SAML Raider

There are multiple variants of XSW attacks from XSW1 to XSW8 (Way of exploitation varies a bit

<https://github.com/swisskyrepo/PayloadsAllTheThings/blob/master/SAML%20Injection/README.md>

XML Attacks

Due to the improper input validation and DTD processing

The SAML implementation might be vulnerable to XXE and XML DoS Attacks like Billion Laughs Attack



SAML Message Integrity Abuse

Using the SAML Message from other users or forged SAML message to bypass the restriction or make unauthorized requests



Missing / Invalid Signature

Missing or Invalid Signature may allow an attacker to forge a signature and abuse the implementation



SAML Message Replay

Assertion ID should be unique and one ID should be accepted only once.

CSRF

Due to improper validation it is possible to carry out CSRF in SAML Implementation

XML Comment Handling

A threat actor who already has authenticated access into an SSO system can authenticate as another user



XSLT

XSLT (eXtensible Stylesheet Transformation Language) Attack can also be leveraged against SAML



Token Recipient Confusion

Attacker's token is used to login to Victim Account.

Labs & Resources

- <https://research.aurainfosec.io/bypassing-saml20-SSO/>
- <https://github.com/yogisec/VulnerableSAMLApp>
- <https://github.com/dogangcr/vulnerable-sso>
- http://sso-attacks.org/Category:Attack_Categorisation_By_Attack_on_SAML
- <https://epi052.gitlab.io/notes-to-self/blog/2019-03-07-how-to-test-saml-a-methodology/>
- <https://epi052.gitlab.io/notes-to-self/blog/2019-03-13-how-to-test-saml-a-methodology-part-two/>
- <https://epi052.gitlab.io/notes-to-self/blog/2019-03-16-how-to-test-saml-a-methodology-part-three/>
- https://github.com/OWASP/CheatSheetSeries/blob/master/cheatsheets/SAML_Security_Cheat_Sheet.md

Report

- <https://hackerone.com/reports/888930>
- <https://hackerone.com/reports/812064>